SOC·L2 · Investigador de incidentes asistido por IA

Informe de síntesis del proyecto · Bootcamp Analista SOC Nivel 2, reto final
Autora: Yahna Chee · Fecha: 7 de noviembre de 2026

1. Objetivo

El cliente de una consultora entregó un Excel con logs de su SIEM y reportó un posible incidente. La herramienta debe buscar indicadores de compromiso, correlacionar eventos, determinar si hubo uno o varios incidentes y generar un informe técnico en PDF. Además, debe cumplir una regla de rigor: ninguna conclusión puede carecer de evidencia en los registros, y cuando los datos no alcanzan se declara «evidencia insuficiente».

2. Arquitectura

El prototipo es un único archivo HTML que se ejecuta en el navegador, sin servidor ni integración con Sentinel. Usa SheetJS para leer el Excel, Chart.js para los gráficos y jsPDF con AutoTable para el informe, todas por CDN con versión fija. El estado vive en memoria; los datos del informe se guardan en `localStorage` y la API key de Gemini, solo en `sessionStorage`.

El flujo sigue al analista y se refleja en siete pestañas: Carga, Eventos, Análisis, Dashboard, Riesgos, Informe y PDF, y Configuración. El procesamiento se divide en cuatro capas:

- **Carga y mapeo.** Acepta varias hojas, y detecta las columnas por nombre y por contenido. Cada lista ofrece primero las columnas sugeridas y oculta las ya asignadas.
- **Detección determinista.** Dieciséis reglas auditables, entre ellas password spraying, fuerza bruta, acceso exitoso tras fallos, PowerShell sospechoso, movimiento lateral, staging, exfiltración, persistencia y webshell. Cada una se mapea a MITRE ATT&CK y muestra su evidencia.
- **Correlación.** Los hallazgos se unen por IP de origen, cuenta comprometida y host (en persistencia), y cada incidente justifica por qué se une o se separa de los demás.
- **Clasificación.** Un incidente es crítico si combina acceso exitoso con una acción posterior, o si hay un shell en el servidor web; en otro caso hereda la severidad máxima de sus hallazgos.

La IA es una capa opcional que solo redacta. Gemini recibe hallazgos estructurados, nunca el Excel, con temperatura baja y salida en JSON. Si su respuesta cita una IP o un Log_ID inexistente en los datos, se descarta. Por su parte, el modelo es configurable, con respaldos automáticos y errores que muestran el código HTTP y el mensaje de Google. Si la IA falla, la herramienta sigue funcionando con las reglas.

3. Datos de entrada y de salida

Sección	Detalle
Entrada	Excel `.xlsx`, hoja «SIEM Export», 715 registros del 2026-10-23 (07:46:07 a 13:44:06), con 12 columnas: Log_ID, Timestamp, Hostname, Event_ID, User, Source_IP, Destination, Log_Source, Event_Description, Process_CommandLine, Result y Severity.
Resultado del análisis	102 eventos sospechosos agrupados en 6 incidentes: 3 críticos (INC-01, INC-02 e INC-06) y 3 altos (INC-03, INC-04 e INC-05).
Salida	Informe PDF de 16 páginas con 12 secciones: resumen ejecutivo, metodología, hallazgos con evidencia, línea de tiempo, IoC, activos afectados, impacto, plan de acción priorizado (P1 a P3) y limitaciones. Incluye los gráficos del dashboard.

En cuanto a los hallazgos principales, INC-01 es un password spraying desde 203.0.113.74 con 33 fallos contra 8 cuentas, seguido de un acceso exitoso y privilegios especiales. A su vez, INC-02 es la cadena más completa: fuerza bruta por RDP, PowerShell codificado, movimiento lateral, acceso al recurso Finance, compresión de archivos y conexión saliente. Por último, INC-06 combina un webshell con un `cmd.exe` lanzado por el pool de IIS. Los tres incidentes altos son PowerShell codificado, staging con conexiones salientes periódicas y persistencia en APP-SRV01.

4. Correcciones durante el desarrollo

Las pruebas expusieron cuatro fallos que condicionaron el diseño final. Primero, Google retiró los modelos Gemini 2.5, lo que causaba errores 404; por eso el modelo pasó a ser configurable, con respaldos. Segundo, el filtro de severidad tenía opciones fijas, así que ahora se construye con los valores reales del Excel, incluidos Informational y Warning. Tercero, el informe afirmaba que no había bytes transferidos aunque los logs traían `bytes_out`; ahora el volumen se calcula (253.305.558 bytes en INC-04) y las limitaciones se generan según los datos. Finalmente, la pestaña Eventos fallaba antes de ejecutar el análisis, error que ya está corregido.

5. Limitaciones

El análisis se basa solo en logs del SIEM, sin captura de red ni EDR, en una ventana de seis horas y sin verificar la reputación de las IPs. Además, hay comandos ofuscados cuya finalidad no se puede determinar y nombres de host inconsistentes (DC-01 y DC01). Por tanto, el éxito de la exfiltración queda como no confirmado.

6. Presentación y repositorio

El video demostrativo dura un máximo de cinco minutos y sigue el orden: estructura del prototipo sin datos, carga del Excel, análisis, dashboard y riesgos, interpretación con Gemini, generación del PDF y conclusiones.

El repositorio de GitHub contiene `index.html`, `README.md`, el informe en `docs/` y los datos de práctica anonimizados. Se publica también como página en GitHub Pages. La API key no se incluye en el código.

- **Video:** https://github.com/yahna-chee/analista-soc-l2/blob/main/videos/ASN2_video.mp4
- **Repositorio:** https://github.com/yahna-chee/analista-soc-l2
- **Informe PDF:** https://github.com/yahna-chee/analista-soc-l2/blob/main/docs/Informe_SOC_L2_2026-11-04%20(v4).pdf
- **Informe del Proyecto final**: https://github.com/yahna-chee/analista-soc-l2/blob/main/docs/Informe%20del%20proyecto%20final.pdf